

4.2 Multi-Factor Authentication

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
Control Definition Control Objective: Prevent that a compromise of a single authentication factor allows access into Swift-related systems or applications by implementing multi-factor authentication. In-scope components (depending on implementation): - dedicated operator PC login - access to jump server and to new HSM - login process to the messaging interface (including a related hosted database), communication interface, Swift and customer connector (including a related hosted database) or a Swift connectivity provider or outsourcing agent Swift-related application - login process to (operating) systems hosting the messaging interface (including a hosted database), Swift and customer connector (including a related hosted database) and communication interface or a Swift connectivity provider or outsourcing agent Swift-related application - login process, for its management, to the externally exposed network device (firewall) protecting the secure zone or the customer client connectors - login process (i) to the GUI on the customer (client) connector accessed for interactive business transaction management or (ii) to the (operating) system hosting the customer (client) connector with privileged accounts - access to the remote Swift infrastructure (that is hosted or operated by a third party, or both) Risk Drivers: - credential replay - password cracking, guessing, or other computational compromise - password theft						
Implementation Guidance Control Statement: Multi-factor authentication is used for interactive user access to Swift-related components or applications and operating system accounts. Control Context: Multi-factor authentication requires the presentation of two or more of the following common authentication factors: - knowledge factor: something the operator knows (for example, a password) - possession factor: something the operator has (for example, connected USB tokens or smart cards, or disconnected tokens such as a (time based) one-time password- (T)OTP- generator or application storing a cryptographic private key that runs on another device like operator's mobile phone considered as a software token, RSA token, 3-Skey Digital and its mobile version considered as a software token, or Digipass) - inherence factor: something the operator is (for example, biometrics such as fingerprints, retina scans, or voice recognition) Implementing multi-factor authentication provides an additional layer of protection against common authentication attacks (for example, shoulder surfing, password re-use, or weak passwords) and provides further protection from account compromises for malicious transaction processing. Attackers often use the privileges of a compromised account to move laterally within an environment and to progress an attack.						

Implementation Guidelines:

The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- When implementing multi-factor authentication, the following principles apply:
 - When based on a knowledge factor (typically a password) combined with a possession factor (a mobile device), the device used for the second factor must not be the same as the device used to enter the first factor. As such, using an app to generate the second factor on the same device/PC used to enter the first factor (password) is not sufficient to access the user's Swift systems.
 - Second factor solutions based on a possession factor include (but are not limited to) TOTP, RSA SecurID, Digipass, Mobile App, Transaction Authentication Number (TAN) Table, 3-Skey Digital and its mobile version, and personal USB token. The solution should be selected per the user's risk management, considering NIST SP 800-63B Authenticator Assurance Level 2 as guidance).
 - An inherence factor is more safely combined with a possession factor than with a knowledge factor.
- Multi-factor authentication is implemented on one authentication stage/step (at minimum) encountered by the system administrator or the end user when accessing a Swift application (interface or connector), the new HSM, the hosting system, or the externally exposed firewalls.
 - Operating system administrators when accessing the hosting system, the new HSM or, from remote, the firewalls that are externally exposed:
 - at the secure zone boundary (jump server)
 - at the dedicated operator PC login (within the secure zone)
 - at the externally exposed firewalls (when technically possible; if not, multi-factor authentication is still required on one stage/step to access such firewalls as for any other system in scope)
 - End users (in descending order of security robustness) when accessing the Swift application or new HSM:
 - on the individual Swift applications (the browser-based GUI, the messaging interface, the communication interface or the (client) connector) in line with the vendor security guidance
 - at the secure zone boundary (jump server)
 - at the dedicated operator PC login (that is, within the secure zone)
- Multi-factor authentication is implemented for remote user administrative access, generally for VPN authentication.
- Multi-factor authentication systems are significantly more exposed if the authentication credentials are stored outside of the secure zone (for example, within an enterprise Active Directory). If possible, then the authentication system that supports the multi-factor solution is located within the secure zone.
- The presented authentication factors are individually assigned and support the individual accountability of access to services, operating systems, and applications.
- If single sign-on (for example, SAML) is implemented, then a second factor is still required at the login or at a later stage.
- When accessing (at least for transaction processing³⁶) a Swift-related service, application, or component that is operated by a service provider multi-factor authentication must be used.

Note: All Swift and Swift-compatible third-party vendor messaging and communication interfaces must support or embed multi-factor authentication.

Considerations for alternative implementations:

When the device used for the second factor is the same as the one used to enter the first factor, additional mitigations must be identified and implemented in line with a user risk assessment (considering NIST SP 800-63B SP Authenticator Assurance Level 2 as guidance).

The objective of the risk assessment is to evaluate and keep potential risks under user's risk appetite when combining factors in case of loss, theft or compromise of such device. Mitigations can include:

³⁶ such as creating, submitting, approving, or modifying transactions or user entitlements.

- (i) technical measures (such as enforcing a PIN or a password to unlock an application linked with the registered device, application that generates a one-time string; limiting the accessed functions depending on the device level of trust; requiring additional factor, such as a biometric factor to unlock cryptographic private key(s) used as possession factor, for most sensitive functions,...) and
- (ii) complementary procedural requirements (such as Policy asking end user to immediately contact a security operations centre -SOC- to block, potentially remote-wipe, or put on-hold any potential access or transaction performed through this lost, stolen or potentially compromised device).